

利用环境变量进行攻击

版权所有 © 2017 杜文亮,保留所有权利。

允许个人使用。如需在课堂上使用这些习题,仅当该课程采用作者的著作作为教材时方可允许。所有其他用途均须事先征得作者的同意。

S3.1. 环境变量和 shell 变量有什么区别?

S3.2. 在 Bash 中,如果我们运行 “export foo=bar”,它会改变环境变量吗?
目前的流程是什么?

S3.3. 以下是打印环境变量的两种不同方法。请描述它们的区别:

```
$ /usr/bin/env $ /usr/bin/  
strings /proc/$$/environ
```

S3.4. 在我们的代码中,当我们使用 `execve()` 执行外部程序 xyz 时, 我们经过
第三个参数为 NULL。运行 xyz 的进程将有多少个环境变量?

S3.5. Bob 说他的代码中从不使用任何环境变量,所以他不必担心环境变量引起的任何安全问题。他的说法正确吗?

S3.6. 程序 abc 使用 `system()` 函数调用外部程序 xyz,而 `system()` 函数受 PATH 环境变量的影响。当我们在 shell 提示符下调用 abc 时,当前 shell 中的 shell 变量 PATH 最终如何影响 `system()` 函数的行为?

S3.7. 请解释为什么使用 `secure_getenv()` 比使用 `getenv()` 更好。

S3.8. 具有特权的 Set-UID 程序需要找出它当前所在的目录。
通常有两种方法。一种是使用 `PWD` 环境变量,它包含当前目录的完整路径。另一种方法是使用 `getcwd()` 函数 (您可以在网上找到它的手册)。请描述您希望采用哪种方法以及原因。

S3.9. 在 Linux 系统中,如果要执行的程序是 Set-UID 程序,动态链接器会忽略许多环境变量。例如,LD PRELOAD 和 LD LIBRARY PATH 就是两个例子。请阅读 ld-linux 的手册 (<https://linux.die.net/man/8/ld-linux>) ,并解释为什么以下环境变量也会被忽略:-

- LD 审计
- LD 调试输出

S3.10. 允许普通用户执行特权任务通常有两种方法:一种是编写一个由 root 用户拥有的 Set-UID 程序,并让用户运行;另一种是使用专用的 root 守护进程为用户执行这些特权任务。请比较这两种方法的攻击面,并说明哪种方法更安全。